

FR-SEC-01 — Role-Based Access Control (RBAC)

Proyek: Aplikasi Mini Bank

1. Pendahuluan

1.1 Tujuan

Menerapkan sistem kontrol akses berbasis peran (*Role-Based Access Control* - RBAC) untuk memastikan setiap pengguna hanya dapat berinteraksi dengan fitur, data, dan antarmuka yang relevan dengan tanggung jawabnya. Hal ini bertujuan untuk mencegah eksploitasi data, meminimalisir kesalahan manusia, dan menegakkan prinsip pemisahan tugas (*Segregation of Duties*).

1.2 Aktor

- **Administrator (Dosen):** Pengelola sistem dan pengguna.
- **Customer Service (CS):** Pengelola data nasabah dan rekening.
- **Teller:** Pelaksana transaksi finansial harian.
- **Supervisor:** Otorisator untuk aksi-aksi sensitif.
- **Unauthenticated User:** Pengguna publik yang belum melewati proses login.

1.3 Ruang Lingkup

- Pembatasan visibilitas menu pada antarmuka pengguna (UI).
- Proteksi URL dan *endpoint* API di sisi server (*Server-side Enforcement*).
- Manajemen pengalihan (*redirection*) saat terjadi upaya akses ilegal.
- Sinkronisasi antara status login, peran aktif, dan hak akses.

2. Deskripsi Fungsional

Sistem mengidentifikasi peran pengguna segera setelah proses autentikasi berhasil. Berdasarkan peran tersebut, sistem akan menyaring komponen UI yang ditampilkan dan memberikan "izin jalan" (*Authorization*) pada setiap permintaan (*request*) yang masuk ke server. Jika pengguna mencoba mengakses fitur di luar otoritasnya (baik melalui menu maupun modifikasi URL manual), sistem wajib melakukan pencegahan seketika.

3. User Stories

ID	User Story
----	------------

US-SEC-01-01	Sebagai CS, saya ingin sistem hanya menampilkan menu nasabah dan rekening agar saya tidak terganggu oleh fitur transaksi yang bukan wewenang saya.
US-SEC-01-02	Sebagai Teller, saya ingin fokus pada modul transaksi dan pencetakan struk tanpa memiliki kemampuan untuk mengubah identitas nasabah.
US-SEC-01-03	Sebagai Supervisor, saya ingin memiliki hak khusus untuk memberikan persetujuan (approval) pada data nasabah yang baru diinput oleh CS.
US-SEC-01-04	Sebagai Sistem, saya harus memblokir upaya akses URL langsung oleh pengguna nakal agar keamanan tidak hanya bersifat kosmetik di UI.

4. Tampilan Antarmuka Pengguna (UI)

- **Menu Dinamis:** Sidebar atau Navbar hanya merender item yang diizinkan untuk peran yang sedang aktif.
- **Halaman Access Denied (403):** Tampilan khusus saat akses ditolak dengan pesan: *"Otoritas Terbatas. Anda tidak memiliki izin untuk mengakses modul ini."*
- **Auth Guard:** Pengguna yang belum login secara otomatis diarahkan kembali ke halaman Login saat mencoba mengakses halaman internal.

5. Matriks Hak Akses (Role-to-Module Mapping)

Modul / Fitur	Admin	CS	Teller	Supervisor
Manajemen Akun (Approval/Role /Suspend)	✓	✗	✗	✗
Manajemen Nasabah (Daftar/Registrasi)	✗	✓	✗	✗

Manajemen Rekening (Buka/Tutup)	✗	✓	✗	✗
Transaksi Finansial (Setor/Tarik/Transfer)	✗	✗	✓	✗
Pencetakan Struk & Bukti Transaksi	✗	✗	✓	✗
Otorisasi/Approval Nasabah & Rekening	✗	✗	✗	✓
Dashboard Utama	✓	✓	✓	✓

6. Aturan Bisnis & Validasi

1. **Default Deny:** Semua akses ke halaman internal dianggap tertutup kecuali secara eksplisit diberikan izin untuk peran tertentu.
2. **Server-Side Validation:** Pengecekan peran wajib dilakukan di level *Interceptor/Filter* pada kode program, bukan hanya sekadar menyembunyikan elemen HTML (seperti tombol atau link).
3. **Session Consistency:** Jika peran pengguna diubah oleh Admin saat pengguna tersebut masih login, sistem harus memastikan hak akses lama segera tidak berlaku (disarankan melalui penyegaran sesi atau *force logout*).
4. **Unauthenticated Handling:** Setiap *request* tanpa *session* aktif wajib diarahkan ke */login*.

7. Persyaratan Non-Fungsional (NFR)

- **NFR-SEC-01-01 Keamanan:** Penanganan error 403 (Forbidden) tidak boleh membocorkan struktur folder atau teknologi *backend* yang digunakan.
- **NFR-SEC-01-02 Audit Trail:** Setiap upaya akses ilegal (Status 403) wajib dicatat dalam log keamanan (User ID, URL yang dituju, IP Address, Timestamp).
- **NFR-SEC-01-03 Performa:** Pengecekan otorisasi tidak boleh menambah waktu latensi *request* lebih dari 50ms.

8. Isu Terbuka

- Apakah Admin diizinkan sebagai *Superuser* (mengakses semua modul) atau tetap dibatasi hanya pada administrasi akun? (Disarankan: Admin hanya fokus pada akun, bukan transaksi operasional).
- Bagaimana penanganan terhadap URL statis seperti gambar atau file PDF nasabah? Apakah perlu diproteksi RBAC juga?

9. Skenario Pengujian (Test Scenarios)

ID	Nama Skenario	Hasil yang Diharapkan
TS-SEC-01-01	CS mencoba akses URL /teller/transaksi	Sistem menolak dan menampilkan halaman 403.
TS-SEC-01-02	Pengguna publik akses /cs/nasabah	Sistem mengalihkan ke halaman /login.
TS-SEC-01-03	Teller melakukan transaksi setor tunai	Sistem mengizinkan aksi dan menyimpan data.
TS-SEC-01-04	Login Admin, verifikasi menu	Hanya menu manajemen akun yang muncul di sidebar.

10. Alur Proses (Flowchart)

graph TD

```

A[User Request URL / API] --> B{Sudah Login?}
B -- Tidak --> C[Redirect ke /login]
B -- Ya --> D[Ambil Role dari Security Context]
D --> E{Role Valid & Terdaftar?}
E -- Tidak --> F[Tampilkan: Role Belum Ditetapkan]
E -- Ya --> G{Cek Matriks Akses: Role Boleh?}
G -- Tidak --> H[Log Percobaan Ilegal & Tampilkan 403]
G -- Ya --> I[Berikan Akses ke Modul]
I --> J[Selesai]
H --> J
F --> J

```